

ISMS POLICY QUESTIONNAIRE

1. ISMS POLICY & GOVERNANCE

- Is there a formal Information Security Policy approved by top management?
- What are the objectives of the ISMS?
- How does the ISMS align with business goals?
- Who approves the ISMS policy?
- How is the policy communicated to employees?
- Where is the policy published?
- How often is the policy reviewed?
- What is the document control process?
- Are policy exceptions allowed? If yes, how approved?
- Who owns the ISMS policy?

2. SCOPE OF ISMS

- What is the defined scope of ISMS?
- Which business units are covered?
- Which locations are included?
- Which systems/applications are in scope?
- Are cloud environments included?
- Are remote workers included?
- What is explicitly excluded?
- How are third-party systems handled?
- Who approves scope changes?
- How frequently is scope reviewed?

3. ORGANIZATION STRUCTURE & RESPONSIBILITIES

- Who is the Information Security Head?
- What is the ISMS governance structure?
- Which departments are involved?
- What are the roles of IT, HR, and management?
- Who is responsible for access control, incident handling, and asset management?
- Is segregation of duties implemented?
- How are responsibilities documented and communicated?
- Who are backup owners for critical roles?
- Who reviews ISMS performance?

4. ASSET MANAGEMENT POLICY

- Is there an asset management policy?
- What types of assets are defined?
- How are assets identified and classified?
- Who owns each asset?
- How is asset inventory maintained and updated?
- How are assets added, removed, or transferred?

5. ACCEPTABLE USE POLICY

- Is there an acceptable use policy?
- What are acceptable and prohibited actions?
- Are password, MFA, antivirus, and patching rules defined?
- What are internet and email usage rules?
- How are violations handled?

6. HUMAN RESOURCE SECURITY POLICY

- Are background checks conducted?
- Are confidentiality agreements signed?
- Is security training provided?
- How are access rights managed during employment?
- How are exits handled and access revoked?

7. PHYSICAL SECURITY POLICY

- What access controls are used?
- Are CCTV, fire protection, and power backup available?
- How are visitors managed?
- How is equipment secured and disposed?

8. OPERATIONS SECURITY POLICY

- Are SOPs defined?
- What is change management process?
- Are logs maintained and protected?
- Are backups taken and tested?
- Is malware protection implemented?

9. NETWORK & COMMUNICATION SECURITY

- Are networks encrypted and secured?

- Are firewalls and VPN used?
- Are logs monitored?

10. INFORMATION HANDLING POLICY

- How is data classified and protected?
- Is encryption used during transfer?
- Are users trained on data handling?

11. ACCESS CONTROL POLICY

- Is access control policy defined?
- Are RBAC and MFA implemented?
- Are accounts reviewed and inactive ones removed?

12. THIRD-PARTY SECURITY

- Are vendors assessed and monitored?
- Are contracts secured with clauses?

13. INCIDENT MANAGEMENT

- How are incidents reported and handled?
- Is root cause analysis done?

14. BUSINESS CONTINUITY

- Is BCP/DR defined and tested?

15. BYOD POLICY

- Is BYOD allowed?
- Are devices registered and secured?
- Is MDM used?
- Is remote wipe enabled?
- Are risks managed?

16. COMPLIANCE & LEGAL

- What regulations apply?
- Are audits conducted?

17. DOCUMENT CONTROL

- How are documents managed, stored, and retained?